

Vendor Management Policy

Langate Group

Purpose

The purpose of this policy is to establish requirements for ensuring third-party service providers/vendors meet Langate Group requirements for preserving and protecting Langate Group information.

Scope

The policy applies to all vendors and partners who have the ability to impact the confidentiality, integrity, and availability of Langate Group's technology and sensitive information or who are within the scope of Langate Group's information security program. This policy also applies to all employees and contractors that are responsible for the management and oversight of vendors and partners of Langate Group.

Background

This policy prescribes the minimum standards a vendor must meet from an information security standpoint, including security clauses, risk assessments, service level agreements, and incident management.

Roles and Responsibilities

- **ISMS Manager** is responsible for implementing and maintaining this policy.

Policy

Langate Group makes every effort to ensure that all third-party organizations (including cloud service providers) are compliant and do not compromise the integrity, security, and privacy of Langate Group or its customer data. Third parties include customers, partners, subcontractors, and contracted developers.

- All vendors are prohibited from accessing Langate Group's information security assets until the appropriate parties agree to and sign a contract containing security controls.
- All vendors and partners accessing Langate Group systems must comply with the security policies set forth in and derived from the Langate Group *Information Security Policy*, including the *Acceptable Use Policy*.
- All vendors and partners must ensure that organizational records are protected, safeguarded, and disposed of securely. Langate Group strictly adheres to all applicable legal, regulatory, and contractual requirements regarding collecting, processing, and transmitting sensitive data such as Personally Identifiable Information (PII).
- Langate Group may choose to audit vendors and partners to ensure compliance with applicable security policies, as well as legal, regulatory, and contractual obligations.

Vendor Inventory

An inventory of third-party service providers shall be maintained and will include:

- Vendor risk level
- Types of data shared with third parties
- Brief description of services

- Main point of contact at the third party
- How access is granted to the third-party vendor
- Significant controls are in place
- Security report and/or questionnaire

Vendor risk level assessment will be based on the following considerations:

- **High:** the vendor stores or has access to sensitive data, and a failure of this vendor would have a critical impact on your business.
- **Moderate:** the vendor does not store or have access to sensitive data, and a failure of this vendor would not have a critical impact on your business.
- **Low:** the vendor doesn't store or have access to any data, and a failure of this vendor would have very little to no impact on your business.

Vendor evaluation approach and criteria:

1. Evaluate the level of risk (only High and Moderate vendors are eligible for review).
2. Is their ISMS certified to ISO/IEC 27001 (preferably 2022 version) or a similar recognized standard (e.g., SOC 2 Type II)?
 - If they are certified:
 - If there is a public Trust Center, conduct an assessment without direct contact with the vendor.
 - In the absence of a public Trust Center, request confirmation of compliance with the standard, including but not limited to:
 - Valid Certificate;
 - Statement of Applicability;
 - Certificate Accreditation Check;
 - Recent Audit Summary, or Attestation Letter.
 - If they are not certified, can they demonstrate an equivalent level of maturity by answering a questionnaire and providing evidence that includes, but is not limited to:
 - Do they have documented information security policies and procedures relevant to the services they provide and the data they handle?
 - Does the vendor perform regular risk assessments?
 - Are they compliant with legal, regulatory, and contractual obligations?
 - How does the vendor handle the confidentiality, integrity, and availability of data?
 - Are appropriate data protection measures in place (e.g., encryption, access control)?
 - Does the vendor manage its own suppliers and subcontractors securely?
 - Does the vendor have an established incident response plan?
 - Does the vendor limit access to your systems or data to authorized personnel only?
 - Are business continuity and disaster recovery plans in place?
 - How quickly can the vendor recover services after a disruption?
3. Availability of alternatives that meet the above requirements and the possibility of their replacement in the future.

Vendor Contracts - General

Formal contracts that address relevant security and privacy requirements must be in place for all third parties that process, store, or transmit confidential data or provide critical services. The following must be included in all such contracts:

- Contracts will acknowledge that the third party is responsible for the security of the institution's confidential data that it possesses, stores, processes, or transmits.

- Contracts stipulate that third-party security controls are regularly reviewed and validated by an independent party.
- Contracts identify information security policies relevant to the agreement.
- Contracts establish training and awareness requirements for specific procedures and information security requirements.
- Contracts identify relevant regulations for subcontracting.
- Contracts implement a monitoring process and acceptable methods for validating the adherence to security requirements of delivered information and communication technology products and services.
- Contracts implement specific processes for managing information and communication technology component lifecycle, availability, and associated security risks.
- Contracts identify and outline use of key controls to ensure the protection of organizational assets – e.g., physical controls, controls for protection against malicious code, physical protection controls, controls to protect integrity, availability, and confidentiality of information, controls to ensure the return or destruction of information assets after their use, controls to prevent copying and distributing information.
- Contracts define information security requirements and identify the owner of the information and how intellectual property rights are regulated.
- Contracts will include screening requirements and background verification checks for contractors, which must be completed prior to joining the organization.
- Screening requirements for personnel provided to Langate Group must be included within the agreement.
- Contracts identify the recourse available to Langate Group should the third party fail to meet the defined security requirements.
- Contracts establish responsibilities for responding to direct and indirect security incidents, including timing as defined by service-level agreements (SLAs).
- Contracts specify the security requirements for the return or destruction of data upon contract termination.
- Responsibilities for managing devices (e.g., firewalls, routers) that secure connections with third parties are formally documented in the contract.
- Contracts stipulate geographic limits on where data can be stored or transmitted.

Vendor Contracts - Cloud Service Providers

Collaborative efforts and responsibilities with cloud service providers will be defined, with consideration given to the following aspects:

- Cloud service selection criteria and scope of cloud service usage;
- Information security controls that are managed by the cloud service provider and those that are managed by the organization as the cloud service customer;
- How to obtain and utilize information security capabilities provided by the cloud service provider;
- How to obtain assurance on information security controls implemented by cloud service providers;
- How to manage controls, interfaces, and changes in services when an organization uses multiple cloud services, particularly from different cloud service providers;
- Procedures for handling information security incidents that occur in relation to the use of cloud services;
- The approach for monitoring, reviewing, and evaluating the ongoing use of cloud services to manage information security risks;
- How to change or stop the use of cloud services, including exit strategies for cloud services.

Formal contracts that address relevant security and privacy requirements must be in place for all cloud service providers that process, store, or transmit confidential data or provide critical services. The following must be included in all such contracts:

- Providing solutions based on industry-accepted standards for architecture and infrastructure;
- Managing access controls of the cloud service to meet the requirements of the organization;
- Implementing malware monitoring and protection solutions;
- Supporting the organization in gathering digital evidence, taking into consideration laws and regulations for digital evidence across different jurisdictions;
- Providing appropriate support and availability of services for an appropriate time frame when the organization

- wants to exit from the cloud service;
- Providing required backup of data and configuration information and securely managing backups as applicable, based on the capabilities of the cloud service provider used by the organization, acting as the cloud service customer.

Langate Group, acting as the cloud service customer, will consider whether the agreement should require cloud service providers to provide advance notification prior to any substantive customer-impacting changes being made to the way the service is delivered to the organization, including:

- Changes to the technical infrastructure (e.g., relocation, reconfiguration, or changes in hardware or software) that affect or change the cloud service offering;
- Processing or storing information in a new geographical or legal jurisdiction;
- Use of peer cloud service providers or other subcontractors (including changing existing or using new parties).

Vendor Contracts - Telecommunications Services

Agreements with primary and alternative telecommunications service providers will include:

- Requirement for contingency plans;
- Contingency plan review to ensure that the plans meet Langate Group's contingency requirements;
- Periodic record of the provider conducting contingency testing and training by providers

Vendor Services Change Management

Changes to the provision of services by vendors, including maintaining and improving existing information security policies, procedures, and controls, should be managed, taking into account the criticality of business information, the systems and processes involved, and the reassessment of risks. The following aspects will be considered:

- Changes to supplier agreements;
- Changes made by the organization to implement:
 - Enhancements to the current services offered;
 - Development of any new applications and systems;
 - Modifications or updates of the organization's policies and procedures;
 - New/changed controls to resolve security incidents and improve security.
- Changes in supplier services to implement:
 - Changes and enhancement to networks;
 - Use of new technologies;
 - Adoption of new products or newer versions/releases;
 - New development tools and environments;
 - Changes to the physical location of service facilities;
 - Change of suppliers;
 - Subcontracting to another supplier.

Policy version history

 Policy details

Policy name	Renewal date
Vendor Management Policy	September 26, 2026
Description	
The Vendor Management Policy defines the rules for relationships with the company's vendors and partners.	

 Version history

Version 1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
June 20, 2024	April 10, 2025	April 10, 2025	Eugene Skubach	Eugene Skubach	Eugene Skubach
Version 1.1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
April 14, 2025	No approval required	April 14, 2025	Eugene Skubach	-	Eugene Skubach
Version 1.2					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
May 6, 2025	No approval required	May 6, 2025	Eugene Skubach	-	Eugene Skubach
Version 1.3					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
July 1, 2025	No approval required	July 1, 2025	Eugene Skubach	-	Eugene Skubach

Version 1.4

Explanation of changes

'Revision History' section has been removed

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
September 26, 2025	No approval required	September 26, 2025	Eugene Skubach	-	Eugene Skubach
